

1. 개념

보안 : 환경에 놓인 보호대상을 위험요소로부터 보호하여 질서와 안녕을 유지하는 활동
정보보호 : 정보의 생애주기(생성~유통~파기) 관점에서 정보를 가지고 있는 자산을 보호하는 활동
사이버보안 : 사이버공간에서 보호대상을 위협으로부터 보호하는 활동
기업보안, 국가보안 : 기업(국가)의 안정적인 비즈니스 활동을 위해 자산(보호대상)을 위협으로부터 보호하는 활동

산업보안 : **“사이버보안 + 시설보안 + 인원보안(사람)”**

- 1) 협의적 개념 : 조직이 **보유한 기술을 보호**하는 것
- 2) 광의적 개념 : 각 산업의 비즈니스 특징을 반영한 “산업의 보안”

연구보안 : 국가연구개발 사업의 전 수행과정에서 발생하는 **주요 연구개발성과**를 유출 또는 침해당하지 않도록 방지하기 위한 활동

(산업)융합보안 : 1) 보안수단의 통합 (**물리보안 + 정보보안**)

- 2) 보안기술과 **타 산업과 융합**을 통한 새로운 가치 창출

물리보안(시설보안) : 1) **물리적 통제 장비**를 통한 보안영역으로 일부 경호 경비 영역 포함

- 2) 전통적인 CCTV, 출입 Gate 등...

국가보안 : 국가를 보안 **인원보안+시설보안+문서보안+전체적인 보안 프로세스**

보호 $\subset$ 보안 // 보안이 더 큰 범주이다!

IT보안 == 사이버보안

IT산업(보안) / 사이버보안 은 어떻게 구성되어 있는가?

CPNT

C Contents : 정보, 데이터, 앱....

P Platform : 서버 `` 등... << 저장되어 있는 곳

N Network : 유/무선, 클라우드, WiFi 등 << 실제로 빼내가는 통로

T Terminal : 기기, 단말기...

공통 보안 기술

1. 암호
2. 인증
3. 접근제어
- 4.로그관리
- 5.백업관리

보안이란? 보안의 구성의 구성요소는? 보안 관리 체계(Security Management Process)는? 안전하다는 것!

APT

A Administration : **관리적** 보안 : 보안 정책, 조직, 사고예방, 사람에 관한 것 등

P Physical : **물리적** 보안 : 출입통제, 주요DB 등의 물리적인 보안

T Technology : **기술적** 보안 : IT 기술 등...

위험

위험 : 외부의 위협이 내부의 취약성을 이용하여 보유한 각종 자산에 피해를 입힐 수 있는 가능성

위험(Risk) = 위협(Threats) * 취약성(Vulnerability) * 자산중요도

위협(Threats) : 자산에 손실을 초래할 수 있는, 원치 않는 사건의 잠재적 원인이나 행위자

취약성(Vulnerability) : 위협에 의한 정보 체계의 모든 정보 보안상의 허점

자산(Asset) : 조직이 보호해야 할 대상 (정보, 하드웨어, SW 등...)

GRC

조직을 안전하게 운영하기 위한 전략과 구조

Governance 거버넌스 : 정책, 규정, 감사

Risk 위험 : 리스크 관리

Compliance 컴플라이언스 : 우리 회사에 맞추기

BS 7799 : 보안 표준 by 영국. 보안이 영국에서 시작됨

ISO 27001 : 보안 국제표준

NIST(미국 국립표준기술 연구소) Security Architecture General 보안 설계 구조

미국표준.

1. **Identify** 인지 :

2. **Protect** 보호 :

3. **Detect** 탐지 :

4. **Respond** 대응 :

5. **Recover** 복구 :

ISMS

정보보안관제시스템(체계) : Information Security Management System

ISO 27001을 따와서 KISA에서 만든 것. 한국표준

보안의 체계를 만들어 놓은 것. APT를 프로세스로 만들어 놓은 것! IT 시스템에 대한 보안 표준

ISMS 인증서 : 보안 관리를 잘 하고 있는지 검사한 인증서

ISMS-P

(IT)보안표준 + 개인정보보호

ISMS와 기존의 PIMS(개인정보보호관리체계) + PIPL(공공기관) 가 합쳐져 만들어짐.

법

영미법 vs 대륙법

영미법 : 판례 근거 -- 우리나라는 영미법

대륙법 : 법전 근거

일반법 vs 특별법

일반법 : 일반적인 내용 broad하게 쓰여져있음 - 개인정보보호법

특별법 : 특수한 내용 specific하게 쓰여져있음 - 의료법

법의 체계

헌법

법률

시행령

시행규칙

고시

가이드라인

개인정보보호법

개인정보보호법 시행령

개인정보보호법 시행규칙

개인정보처리방법에 관한 고시

온라인 개인정보 처리 가이드라인 등...

<< 모든게 자세하게 설명되어 있음!!

데이터 3법 개. 망. 신.

1. 개인정보보호법

개인정보 보호에 관한 내용.

2. 정보통신망법 (정보통신망 이용촉진 및 정보보호 등에 관한 법률)

해킹사고 등에 대비한 정보보호에 관한 내용.

3. 신용정보법 (신용정보의 이용 및 보호에 관한 법률)

돈에 관련 된 것.

* 정보통신망법에서 개인정보 내용이 다 삭제되고 개인정보보호법이 생김!

OECD 개인정보 보호 8원칙

개인정보 보호법의 근간

- | | |
|-----------|--------------------------------------|
| 1. 수집제한 | 꼭 필요한 정보만 수집 |
| 2. 정보정확성 | 정보를 정확히 수집 |
| 3. 목적구체성 | 목적은 구체적으로 |
| 4. 이용제한 | 동의받은 목적으로만 사용해야 함. |
| 5. 안정성 확보 | 개인정보를 안전하게 보호해야 |
| 6. 공개 | 정보주체가 요청하면 쉽게 알도록 어떻게 처리되고 있는지 밝혀야 함 |
| 7. 개인참여 | 개인정보 자기결정권 |
| 8. 책임 | 위 내용을 지키도록 할 책임이 있음 |

보안책임자 종류

CSO : Chief Security Office	최고 보안 책임자. 기업 전반적인 보안.
CISO : Chief Information Security Officer	최고 "정보보안" 책임자. IT총괄.
CPO : Chief Privacy Officer	최고 개인정보 책임자.
DPO : Data Protection Officer	주로 EU에서. CPO와 같음.

개인정보 보호법

- 1장 총칙 : 개인정보의 정의, 개인정보 보호원칙, 정보주체의 권리, 다른 법률과의 관계
- 3장 개인정보의 처리 : 개인정보 수집, 이용, 제공, 파기. 개인정보 처리 제한
- 4장 안전한 관리 : 안전조치 의무(APT), 보호책임자 처리방침... << APT 중 주로 T. 기술적 내용
- 5,7,8장 권리보장 및 구제 : 정보주체의 권리 보장, 개인정보 분쟁조정, 단체 소송

개인정보란?

‘살아있는 개인’에 관한 정보 : 자연인에 대한 모든 정보. 모든 사람. 국적이나 신분에 관계없음.

‘개인’에 관한 정보 : 법인, 단체의 정보는 해당 無

정보의 내용·형태는 제한 없음

① 개인을 알아볼 수 있는 정보 이름, 주민번호 등...

② 다른 정보와 쉽게 결합하여 알아볼 수 있는 정보

③ 가명정보 : 가명처리를 하여 복원하기 위한 추가 정보의 사용·결합 없이는 개인을 알아볼 수 없는 정보

>> 익명정보 : 추가 정보의 사용·결합을 해도 개인을 알아 볼 수 없는 정보.

개인정보 보호법에서의 개인정보에 해당하지 않음.

Q) 공적 생활에서 형성된 정보, 이미 공개된 정보도 개인정보에 해당하는가?

A) YES. 이미 공개된 개인정보도 포함됨.

Q) 휴대전화 뒤 4자리는 개인정보에 해당하는가?

A) YES. 뒤 4자리로도 개인을 식별할 수 있고, 다른 정보와 결합하면 누구인지 알 수 있다.

Q) 아파트 RFID 음쓰기계의 음성 동-호수는 개인정보인가?

A) YES. 동의를 받거나, 법에 근거가 없는 한 알림이 나오지 않도록 해야 한다.

용어 정리

정보주체 : 처리되는 정보에 의해 알아볼 수 있는 그 정보의 주체가 되는 사람.

개인정보 처리자 : 업무를 목적으로 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 **공공기관, 법인, 단체, 개인** 등

개인정보 취급자 : 개인정보 **처리자의 지휘**를 받아 개인정보를 처리하는 **임직원, 파견, 시간제근로자** 등

개인정보 보호 책임자(CPO) : 개인정보 처리에 관한 업무를 총괄해서 책임지거나 업무처리를 최종적으로 결정하는 자.

개인정보 파일 : 개인정보가 들어있는 엑셀이나 DB

개인정보 처리시스템 : DB 시스템 등 체계적으로 구성한 응용시스템

영상정보처리기기(CCTV) : 일정한 공간에 지속적으로 설치되어 촬영, 이를 전송.

제3자제공 : 사업자가 자신의 업무나 이익을 위해 제3자로부터 개인정보를 제공받는 경우

위수탁 : 위탁자(개인정보처리자)가 수탁자(제3자)에게 위임하여 개인정보를 처리하는 것

정보통신서비스 제공자 : **전기통신사업자** or 영리를 목적으로 **정보를 제공**하거나 **정보통신제공을 매개**하는 자
>>통신사, 온라인 사이트 등등 광범위

개인정보 보호원칙

OECD 8원칙에 기반

- | | |
|---|------------|
| 1. 처리목적의 명확화 , 목적 내에서 적법하고 정당하게 최소 수집 | 목적명확성 수집제한 |
| 2. 처리목적 내에서 처리. 목적 외 활용 금지 | 이용제한 |
| 3. 처리 목적 내에서 정확성·완전성·최신성 보장 | 정보정확성 |
| 4. 정보주체의 권리침해 위험성 등을 고려하여 안전하게 관리 | 안정성 확보 |
| 5. 개인정보 처리사항 공개 , 정보주체의 권리보장 | 공개, 개인참여 |
| 6. 사생활 침해 최소화 방법으로 처리 | + |
| 7. 가명/익명 처리가 가능한 경우 가명/익명처리 | + |
| 8. 개인정보처리자의 책임준수, 정보주체의 신뢰성 확보 | 책임 |

정보주체의 권리

1. 개인정보 처리에 관한 정보를 **제공받을 권리**
2. 개인정보의 처리에 관한 **동의 여부, 범위** 등을 **선택, 결정**할 권리
3. 개인정보의 처리 여부 확인, 개인정보 **열람**을 요구할 권리
4. 개인정보의 **처리 정지, 정정·삭제 및 파기**를 요구할 권리
5. 개인정보의 처리로 인한 **피해**를 신속, **공정하게 구제**받을 권리

개인정보 보호법 개정내용

1. 개인정보 보호체계 일원화 : 감독기구 및 관련 법령 정비
2. 데이터 이용 활성화 : **가명정보** 도입 등 데이터 활용 근거 마련. **양립성**에 근거한 개인정보의 목적 외 이용·제공
3. 개인정보처리자 책임성 강화 : 가명 정보의 안전한 활용을 위해 **안전조치 의무** 부과

1. 개인정보 보호 체계 일원화

- * 여러 위원회, 부처에 있던 개인정보 보호 관련 업무를 '개인정보보호위원회'로 통합·이관.
>>중앙행정기관으로 격상. 여러 부처 업무 통합. 감독체계 구축

- * 정보통신망법과의 통합. 법령 일원화

방법의 유사 내용을 개보법에 통합하고, 망법에서의 고유규정은 특례를 신설해 이관

2. 데이터 이용 활성화

- * 개인정보의 이용·제공 범위 확대 : 수집 목적 + 합리적인 범위 내에서 동의 없이 이용 가능해짐
but, 범위 내에서 안전성 확보 조치를 했는지 등 고려
- * 가명정보의 이용·제공 범위 확대 : 통계작성, 과학적 연구, 공익적 기록 보존에 사용 가능해짐.

*개인정보 개념 명확화 : 개인, 가명, 익명정보 개념 명확화

★익명정보는 개보법 적용 대상이 아님.★

 개인정보	특정 개인에 관한 정보, 개인을 알아볼 수 있게 하는 정보 예) 홍길동, 32살, 남성, 서울시, 마포구 공덕동, 010-1234-5678
 가명정보	추가정보의 사용 없이는 특정 개인을 알아볼 수 없도록 한 정보 예) 홍xx, 32살, 남성, 서울시, 마포구, 010-xxxx-xxxx
 익명정보	더 이상 개인을 알아볼 수 없도록 한 정보 예) 서울 사는 30대 남성

✓ **가명정보**
원래의 상태로 복원하기 위한 추가 정보의 사용 결합 없이는
특정 개인을 알아볼 수 없는 정보

✓ **가명처리**
개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하는 등의
방법으로 추가 정보가 없이는 특정 개인을 알아 볼 수 없도록
처리하는 것 (개인정보보호법 개정 제2조)

✓ **가명정보의 처리**
통계작성, 과학적 연구, 공익적 기록보존 등의 목적으로
정보주체의 동의 없이 가명정보 처리 가능
(개인정보보호법 개정 제28조의 2(가명정보의 처리 등))

- * 데이터 결합을 위한 법적 근거 마련 : 가명정보 결합에 대한 법적 근거 명시

기업 내부 결합 - 자체적으로 결합

기업 간 결합 - 보안시설을 갖춘 전문기관 내에서.(KISA 등...)

외부 반출 시 - 가명 또는 익명처리 후 전문기관의 승인을 거쳐 반출

3. 개인정보처리자의 책임성 강화

- * 가명정보에 대한 안전조치 의무(APT) 부과. 위반 시 과태료 및 형사처벌
- * 재식별 금지. 위반시 과태료 및 형사처벌

* 추가정보(원상태로 복원하기 위한 정보) 별도 분리·보관 관리. APT 보안조치 必. 가명정보 처리기록 작성·보관

* 가명정보 처리시 금지의무 : 특정 개인을 알아보기 위한 목적으로 처리 금지. 만약 생성되면 즉시 처리중지, 회수, 파기

+양벌제(쌍벌제) : 행위자(직원) + 책임자(사장)도 같이 처벌

프라이버시

1)헌법상 개인정보자기결정권(개인정보 통제권)의 보호 + 2) 혼자있을 권리 + 3) 개인정보

헌법상 개인정보자기결정권 : 정보주체가 개인정보의 공개와 이용에 관하여 스스로 결정할 권리

헌법상 개인정보 : 개인의 동일성을 식별할 수 있게 하는 일체의 정보. 공적 정보, 이미 공개된 정보 포함.

개인정보는 공공재인가? 답은 세모!

공공재 : 비경합성(누가 쓰면 없어지는가? X) & 비배제성(돈 낸사람만 쓸수있는가? X) => 조건은 만족

>> 비식별화, 익명화, 가명화 등 안전장치 + 다양한 안전장치 마련 후 공공재로 활용하여야!

>> 공공재를 내것처럼 이용하지 않을 수 있음.

*Null Usage Data :

개인정보의 처리

개인정보의 생명주기

수집 -> 이용- > 제공 -> 관리(보유or 저장) -> 파기

개인정보 수집·이용

1. 정보주체의 동의를 받은 경우. 고지 의무 사항) ①목적 ②항목 ③보유·이용 기간 ④거부 권리 및 불이익 내용
2. 법률의 특별한 규정, 법령상 의무 준수를 위해 불가피한 경우
3. 공공기관이 법령 등에서 정한 소관업무를 위해 불가피한 경우
4. 정보주체와의 계약 체결·이행에 불가피한 경우
5. 개인정보처리자의 정당한 이익 달성을 위해 필요한 경우로서 명백하게 정보주체의 권리보다 우선하는 경우

개인정보의 수집 제한

- * 필요 최소한의 개인정보 수집
- * 최소한이라는 입증책임은 개인정보처리자가 부담.
- * 필요 최소한의 정보 외의 개인정보 수집에는 동의 거부 가능
- * 최소한의 개인정보 이외의 개인정보 수집을 동의하지 않는다는 이유로 재화 등 거부 금지. 위반시 3천▼ 과태료
과태료 vs 과징금 : 과태료 - 법령 위반에 대해서 부과. 벌금은 아님 과징금 - 규약 위반에 대한 제재로 징수

제3자 제공(개인정보 수집 목적 범위 내)

- * 정보주체의 동의를 받은 경우. 고지 의무 사항) ①목적 ②항목 ③보유·이용 기간 ④거부 권리 및 불이익 내용
- * 법률의 특별한 규정, 법령상 의무 준수를 위해 불가피한 경우
- * 공공기관이 법령 등에서 정한 소관업무를 위해 불가피한 경우
- * 명백히 정보주체 등의 급박한 생명, 신체, 재산의 이익을 위해 필요한 경우

제3자 제공(개인정보 수집 목적 범위 외)

목적 외 이용·제공 원칙적 금지.
별도 동의를 받거나 법률의 특별한 규정, 명백히 정보주체나 제3자에게 필요한 경우
+ 공공기관에서 꼭 필요할 경우
제공받는 자는 기술적 조치를 해야 함.

개인정보의 수집 출처 등 고지

정보주체의 요구가 있으면 즉시 출처, 목적, 처리 정지를 요구할 권리가 있음.

고지의무 대상 : 5만명 이상 민감, 고유식별정보 처리자 | 100만명 이상 개인정보 처리자

개인정보의 파기

불필요하게 되었을 때 지체없이 파기. 복구, 재생되지 않도록 조치. 법령에 따라 보존해야 하면 분리조치.

동의받는 방법

- 각각의 동의사항을 구분해야 함.
- 동의없이 처리할 수 있는 개인정보와 동의가 필요한 개인정보를 구분해야 함.
- 선택사항을 동의하지 않는다고 제공을 안하면 과태료
- 만 14세 미만 아도의 개인정보를 처리하려면 법정대리인의 동의를 받아야 함.

표기사항 : 민감정보, 여권번호, 운전면허번호, 외국인등록번호, 보유&이용, 기간, 목적
표기방법 : 글씨 9pt 이상

민감정보, 고유식별정보 처리제한

- 원칙적 처리 금지.
- 동의를 얻거나 법령에서 허용하는 경우.
 - 민감정보 : 사상, 신념, 노동조합 가입, 건강, 유전, 범죄경력, 바이오, 인종, 민족 정보
 - 고유식별정보 : 주민등록번호, 여권번호, 운전면허번호, 외국인등록번호

>> 분실·도난·유출·위조·변조·훼손되지 않도록 **안전성 확보조치** 의무.

주민등록번호의 처리제한

- ★주민등록번호는 **동의만으로 처리 불가!**★
- * 법률에서 구체적으로 요구, 허용한 경우
- * 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 명백히 필요하다고 인정되는 경우

인터넷으로 회원 가입 시 **주민번호를 사용하지 않는 가입 방법**을 제공하여야 함.

Q) 채용재원서에 주민등록번호를 기재하도록 요구하는데 적법한가요?

A) NO, 예외적인 사유가 존재하지 않으면 금지.

영상정보처리기기의 설치·운영 제한

- * 다음 경우를 제외하고는 공개된 장소에 영상정보처리기기 설치·운영 금지
 - 법령에서 구체적으로 허용
 - 범죄의 예방 및 수사 위한 경우
 - 시설안전 및 화재 예방을 위하여 필요한 경우
 - 교통단속, 교통정보 등을 위한 경우
- * 목욕실, 화장실, 발한실, 탈이실 내부는 금지
- * 설치 목적과 다른 목적으로 임의조작, 다른곳을 비추기, 녹음 등 금지
- * 안내판 설치 및, 안전성 확보조치 해야함(분실,도난,유출,위조,변조,훼손) 등 되지 않도록

Q) 안내판은 영상정보처리기기가 설치된 곳마다 설치해야 하는가?

A) 출입구 등 잘 보일수 있는 곳, 장소 전체가 설치 지역임을 표시하는 안내판

업무위탁에 따른 처리 제한

- *개인정보 처리업무 위탁을 **문서화** 해야함.
 - 위탁업무 외 개인정보 처리 금지. 기술적, 관리적 보호조치
 - 목적 및 범위 재위탁 금지 등.....
- *홈페이지 등에 업무 내용 , 수탁자 공개해야 함
- * 홍보나 판매 권유 업무 위탁 시 정보주체에게 통지
- * 위탁 받은 업무를 초과한 개인정보 이용 및 제3자 제공 금지(징역 및 벌금)

개인정보의 안전한 관리(APT)

안전조치의무

개인정보가 분실·도난·유출·위조·변조·훼손되지 않도록 **안전성 확보 조치**를 해야 함 >>APT로 해야 함

분실 : 의도하지 않게 잃어버리는 것

도난 : 타인이 의도적으로 훔쳐간 것

유출 : 정보가 새어나가는 것. 외부 등 악의적 공격에 의해서 새어나가는 것

위조 : 실제와 동일하게 보이게 가짜를 만드는 것

변조 : 원본을 고의로 변경하거나 왜곡하는 것

훼손 : 물리/비물리적 손상을 입는 것

>>노출 : 처리자의 실수로 누구든지 볼 수 있게 되는것

* 내부 관리계획 수립·시행 --- 관리적

* 개인정보처리시스템 접근 권한 --- 관리적

* 개인정보처리시스템 접근 통제 --- 물리적

* 개인정보 암호화, 접속기록 관리 --- 기술적

개인정보 처리방침의 수립 및 공개

: 인터넷 홈페이지에 지속적을 게재하여 공개해야 함! 목적, 처리/보유기간 등 11가지...

개인정보 보호책임자의 지정

CPO, DPO를 지정.

개인정보 보호 계획 수립 및 시행 등 업무...

개인정보 보호책임자의 지정 요건

지정 요건이 있음. 3/4급 이상 공무원.

사업주 또는 임원

개인정보파일의 등록 및 공개 << 공공기관만 해당

개인정보파일의 명칭, 운영, 근거, 목적 등...

공공기관의 명칭, 정보주체 수, 개인정보 처리업무 담당 부서

+ 예외 : 국가안전/비밀 등. 범죄/수사/교정 관련. 관세법/조세법 관련, 내부적 업무처리만을 위한 파일. 비밀

개인정보 보호 인증 평가

개인정보처리자의 일련의 조치가 법에 부합하는지 등에 관하여 인증

ISMS-P : 정보보호 및 개인정보 보호 관리체계 - 유효기간 3년. 1년마다 증적

개인정보 영향평가(PIA) << 공공기관만 해당

개인정보가 유출됐을 때 “사전에” + “지금 운용중인” 개인정보 파일 어떤 영향을 미칠지 미리 예측 평가

대상 :

구축, 운용, 변경하려는 개인정보파일. 5만명 이상 정보주체의 민감, 고유식별정보의 처리가 수반

구축, 운용하려는 개인정보파일과 다른 개인정보파일과 연계

개인정보 유출 통지

개인정보 유출 사실을 인지 하였을 경우에는 지체없이 정보주체에게 관련 사실을 통지해야 함

118 : 한국인터넷진흥원

개인정보의 열람

정보주체는 자신의 개인정보에 대한 열람을 요구 가능.

정보주체는 열람하려는 사항을 개인정보처리자가 마련한 방법과 절차에 따라 요구하여야 함.
서면, 전화, 인터넷 등 쉽게 활용할 수 있는 방법을 제공해야 한다.
10일 이내에 정보주체가 열람할 수 있게 해야함.
사유를 알리고 열람 제한·거절 가능.

개인정보 피해구제 제도 현황

1. 개인정보침해 신고상담
2. 개인정보분쟁조정
3. 민사소송

손해배상제도

징벌적 손해배상제도 : 처리자의 고의·중과실로 개인정보 유출 | 동의 없이 활용하여 피해 발생
처리자가 고의·중과실 없음을 입증해야 함. <-> 피해액은 피해자가
재산+정신적 피해액
법적 손해배상제도 : 법에서 정한 한도 내에서 손해배상

정보통신서비스 제공자 등에 대한 개인정보 처리 등 특례

정보통신서비스 : 전기통신역무와 이를 이용하여 정보를 제공하거나 정보를 제공하거나 정보의 제공을 매개하는 것
정보통신서비스 제공자 : 전기통신사업자 + 이를 이용하여 정보를 제공하거나 정보의 제공을 매개하는 자
통신사, 은행, 앱 등등 광범위

개인정보의 수집·이용

이용자의 동의 + 동의 없는 수집·이용(계약을 이행하기 위해, 요금정산을 위해....)

개인정보의 수집제한

필요한 **최소한의** 개인정보만 수집
최소 외에 개인정보 거부 가능해야함.

14세 미만 아동의 보호

본인이 아닌 법정대리인의 동의를 받을 것
알기 쉬운 언어를 사용해야 함

개인정보 유출 등의 통지 신고

개인정보 유출 등의 통지 : 유출 등을 안 때부터 24시간 내 지체없이 이용자에게 통지해야 함
개인정보 항목, 시점 이용자가 할 수 있는 조치 제공자의 조치 연락처
개인정보 유출 등의 신고 : 안 때부터 24시간 내에 KISA에 신고
통지·신고의 지연 및 보완 : 24시간 내 통지·신고할 수 없는 정당한 사유가 있으면 보호위원회에 소명

개인정보의 안전성 확보조치

접속기록(log) 위·변조 방지
개인정보의 안전한 저장·전송을 위한 보안조치 : 비밀번호 **일방향 암호화 저장(HASH 함수)**
백신 등...

개인정보 유효기간제

장기 서비스 미이용자의 개인정보 파기 또는 별도 보관
파기 또는 별도 보관

Q) 위탁사를 대신하여 개인정보를 처리하는 수탁사도 보험에 가입하거나 준비금을 적립해야 하는가? 위탁사는 접근 권한 only

A) 의무가 적용되지는 않음. 위탁사가 보험에 가입해야 함.

노출 개인정보의 삭제·차단

개인정보 노출방지 의무 : 정보통신서비스 제공자는 이용자의 개인정보에 대해 노출방지 의무를 해야 함
노출 개인정보에 대한 조치 의무 : 개보위, KISA에 삭제·차단 조치를 해야 함.

국내대리인의 지정

해외사업자는 국내대리인을 지정해야 한다.
일정규모 이상 회사. 일정조건 이상 대리인.

프라이버시 vs 개인정보

개인정보 자기결정권 + 혼자있을 권리 + 개인정보

개인정보 영향평가제도 (PIA)

새로운 정보시스템의 도입과 개인정보의 수집에 앞서 계획하고 있는 시스템이 구축, 운영될 경우 프라이버시에 미칠 영향에 대하여 미리 조사, 예측, 검토하는 체계적인 절차를 의미

- * 개인정보를 다량으로 보유, 관리하는 정보시스템의 신규 구축
- * 프라이버시 침해 가능성이 있는 기술을 사용하는 사업
- * 기존 정보 시스템을 변경하려는 경우
- * 개인정보 생명주기 단계에서 침해 우려가 발생할 수 있는 사업
- * 다른 기관과 연계하려는 경우



ISMS (정보보호 관리체계) 인증

개인정보보호법 위반 사례

개인정보보호위원회와 과태료(행정처분)을 할 경우

질서 위반 행위 규제법 + 개인정보보호법으로 처분
위반 횟수에 따라 부과 금액 차등

주요 공공기관에 대해 개인정보 실태점검

- 1) 주요 공공기관 홈페이지 보안 2) 지방자치단체 3) 의료, 복지 4) 고용 5) 부동산

현장점검 법적 근거

개인정보보호법+개인정보보호법 시행령

수집

- 수집을 해야 함.
- 거부할 수도 있어야 함
- 동의를 거부할 권리가 있다는 사실 + 그 거부에 따른 불이익이 있는 경우 불이익도 알려줘야 함.
- if 제3자 제공에 대한 동의를 받지 않으면 -> 위반
- if 마케팅 광고에 대한 **개별동의**를 받고 있지 않으면 -> 위반

파기

- 홈페이지 회원탈퇴 시 일부 정보 미 파기 -> 위반
- 개인정보를 보존해야 하는 경우 다른 개인정보와 분리해야 함/

위탁

- 위·수탁 계약서 : 표준 개인정보처리 위탁 계약서
- 위탁 시 정보주체가 언제든지 쉽게 확인할 수 있게 개인정보 **업무 위탁 내용**을 공개해야 함!

개인정보 처리방침

제3자 제공, 위탁, 안전성 확보조치에 관한 사항을 개인정보 처리방침에 공개하지 않음...! -> 위반

유출 시 통지

- 개인정보 처리자는 유출되었음을 알게되었을 때 다음 사실을 알려야 한다.
- 1. 유출된 개인정보의 항목
- 2. 유출된 시점과 경위
- 3. 정보주체가 피해를 최소화하기 위하여 할 수 있는 방법
- 4. 개인정보처리자의 대응조치 및 피해 구제절차
- 5. 신고 등을 접수할 수 있는 담당부서 및 연락처

개인정보 안전성 확보조치

APT를 위반한 것 특히 T를 위반한 것

안전조치의무

- 내부 관리계획의 수립·시행
- 개인정보처리자는 분실·도난·유출·위조·변조·훼손되지 아니하도록 내부 의사결정을 통해 내부관리계획에 안전성 확보를 위한 조치를 수립·실행시켜야 한다.
- >>각 회사마다 개인의 고객정보가 다르기 때문에 회사마다 내부관리계획이 달라진다.

접근권한 관리

- 처리자는 권한 부여, 변경, 말소에 대한 내역을 기록하고 그 기록을 최소 3년간 보관해해야 함.
- 비밀번호 작성규칙을 수립해야 한다.
- 비밀번호 일정 횟수 이상 잘못 입력하면 접근을 제한하는 기술적 조치를 해야 한다.

접근통제

- 접근통제 : 인가된 사용자만 접근이 가능하도록 함 - VPN 사용 등
- <-> 접근권한 : 사용자의 허가된 행동의 범위를 다르게 함.

개인정보의 암호화

- 고유식별정보, 비밀번호 등 송신하거나 전달하는 경우 암호화하여야 한다.
- 세부 내용은 가이드라인을 봐야 한다.
- 비밀번호는 일방향 암호화(HASH 함수)

접속기록의 보관 및 점검(로그)

- 개인정보 취급자가 시스템에 접속한 기록을 1년 이상 기록해야 함
- 계정, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등

악성프로그램 등 방지

- 백신 등 보안 프로그램을 설치·운영해야 함

물리적 안전조치

- 개인정보가 포함된 서류, 보조저장매체 등을 잠금 장치가 있는 안전한 장소에 보관하여야 한다.

개인정보 유출·노출 예방

CPNT의 전 영역에서의 유출·노출 예방

위조 vs 변조

유출 vs 노출 : 유출 - 고의, 악의에 의해서 밖으로 새어 나감. 노출 - 부주의, 실수에 의해서 누구나 접근 가능하게 드러남

유출과 노출의 개념

- 유출 : 처리자가 통제를 상실하거나 또는 권한 없는 자의 접근을 허용한 경우
- 노출 : 공개되어 누구든지 알아볼 수 있는 상태

개인정보 노출 모니터링

- 개인정보가 노출됐는지 모니터링하는 것. 노출 검사.
- 고유식별정보 등 사생활 침해가 우려되는 정보가 노출
- 개인정보취급자 : 홈페이지에 노출된 개인정보를 신속히 삭제하지 않을 경우 피해 확산.

개인정보 유·노출 시 조치사항

노출

- 신속히 노출 페이지 삭제 또는 비공개
- 엔진에 노출되었으면 삭제 요청. 로봇 배제규칙 적용
- 접속 경로 차단
- 백신 최신으로 업데이트

유출

- 지체없이 정보주체에게 통지. with 유출 시 통지 5가지!
- 피해 최소화를 위한 대책 마련 및 필요한 조치 실시
- 1천명 이상 유출된 경우 KISA 신고

기관에 대한 조치

개인정보가 노출된 기관에 삭제 등 조치하도록 즉시 통보
재발방지 협조 요청 공문 발송
노출 기관 담당자 대상 “개인정보 노출 재발방지” 교육 필수

=>반복·대량 노출 기관 및 교육 미참석 기관의 경우, 개인정보 관리실태 특별점검 대상에 포함 가능

개인정보 유·노출 후속조치

안전조치 의무 : 개인정보 또는 고유식별정보가 분실·도난·유출·변조·훼손되지 않도록 APT 조치 이행

안전성 확보 조치 : 개보위가 정하여 고시

DMZ : 내부망과 외부망 사이에서 불특정 다수가 볼 수 있는 중간 구역

>>여기에 고유식별정보를 저장하는 경우 암호화를 해야 함

개인정보 유·노출 사례 및 조치

공공 - 개인정보 노출, 탐지, 삭제 홈페이지는 15년 이후 감소 추세였으나 19년도 탐지 유형 확대로 인해 증가.

민간 - 지속적으로 증가하는 추세

개인정보 유·노출 사례

면접 메일 안에서 지원자 전체 개인정보가 나타남.

구 시스템 방치. 관리자 페이지 개인정보 노출

OCR로 PDF가 검색엔진에 탐지되어 홈페이지 게시판에 주민등록번호가 담긴 첨부파일 노출

개인정보 유출 원인

- 1위 해킹 : 웹shell 업로드(악성 스크립트를 업로드해서 공격), 파라미터 변조(URL, 쿠키, 필드 등 파라미터 값을 공격자가 수정해서 서버에 잘못된 값 전송), SQL 인젝션 등 해킹 공격
- 2위 업무과실 : 담당자 실수로 인한 이메일 오발송. 접근통제 미흡으로 검색엔진에 노출
- 3위 고의유출 : 퇴사 시 USB에 다운로드. 홍신소를 통한 파일 구매. 업무담당자가 무단 제공

외부 공격

DB 관리자페이지 공격으로 인한 유출

접속권한을 IP, 포트, MAC 주소 등으로 제한하여 인가받지 않은 접근을 제한.(접근통제)

안전한 접속수단 or 안전한 인증수단

안전한 비밀번호 사용

SQL 인젝션 공격으로 인한 개인정보 유출

웹방화벽, IDS 등을 구축 운영

쿼리문의 입력데이터 검증

계정 권한 제한, 최소한의 권한만 부여

지능형 지속공격(APT)

: 장기적으로 목표를 삼아 정교하고 지속적인 해킹을 시도하는 공격

고의(내부직원 유출)

업무 담당자가 지인의 부탁을 받고 고객정보 유출

개인정보 취급자 교육, 보안 USB, 시건장치가 있는 캐비닛